

사전 제출 요청 자료 목록

■ 방문 전 사전 제출 자료 — [기업 입력란]에 직접 기입해 주시고, '별도 파일 제출' 항목은 관련 파일을 이메일 제출해 주십시오.

번호	구분	요청 자료 / 입력 항목	기업 입력란 (양식 입력 시)	요청 목적	입력 가이드 / 작성 기준
1	기본 정보	조직도 (부서 구성, CPO/정보보호담당자 명시)	조직도 확보 필요	조직 규모, 책임 체계, 접근권한 구조 파악	CPO 직위·부서 명시, 개인정보 취급 부서 표시
2		임직원 수 (정규직/비정규직 구분)	기업 확인 필요	조직 규모, 교육 대상 범위	정규직 기준 또는 총원 명시 (예: 정규직 15명, 비정규직 5명)
3		개발자/기술 인력 수	기업 확인 필요	기술 운영 역량 파악	블록체인/백엔드/프론트엔드 구분 기재
4		보안 전담 인력 수 (겸직 여부 포함)	기업 확인 필요	보안 운영 역량 파악	0, 1, 2... (겸직 여부 명시)
5		정보보호/개인정보보호 담당자 유무	기업 확인 필요	담당 체계 확인	예/아니오 (보유 시 담당자 직위)
6		24x7 운영/관제 여부	기업 확인 필요	운영 성숙도 파악	예/아니오
7	서비스·기술 구성	블록체인 서비스 개요 (서비스 명, 목적, 주요 기능) 및 이를 확인할 수 있는 자료	SOH_DID: DID-지갑-토큰 API 공식명출시·이용자 수 확인	평가 범위 설정, 블록체인 활용 내역 파악	서비스 명, 출시일, 주요 기능, 사용자 수(대략)
8		블록체인 유형 (퍼블릭/프라이빗/컨소시엄, 플랫폼)	DChain/Mitum, 기본 minic 체인 유형·운영망 확인	진단 난이도/포인트 구분, 노드 운영 구조	Ethereum, Klaytn, Polygon, Hyperledger 등
9		서비스 운영 단계	운영 단계 확인 필요	운영 현황 파악	메인넷 운영 중 / 테스트넷 단계 / 개발 완료 후 오픈 예정
10		스마트컨트랙트 운영 여부 및 개수	토큰 API 구현; 배포 수 확인	심층 진단 필요성 및 범위 판단	보유 컨트랙트 수, 자체 개발 여부, 주요 기능
11		지갑/수탁/키관리 기능 보유 여부	키관리 구현 있음; 서식7 참조	고위험 기능 식별, 키관리 점검 범위	예/아니오 (보유 시 관리 방식 개요)
12		주요 시스템 구성 (웹/앱/API/노드/DB/클라우드)	Flask/MySQL-파일·DChain	현장 점검 범위 정의	대략적 구성 (예: 웹 서버 2대, API 서버 1대, DB 1대, 블록체인 노드 3대)
13		클라우드 사용 여부 및 사업자	AWS EC2 예시; 실사용 확인	기술/관리 보호조치 확인 경로	AWS/Azure/GCP/NCP/온프레미스
14		노드 직접 운영 여부	외부 API 사용; 직접운영 확인	인프라 진단 범위 판단	예/아니오 (운영 시 노드 수, 유형)
15	개인정보 처리 현황	개인정보 처리 여부	식별자·주소 처리; 실범위 확인	개인정보 보호조치 점검 필요성	예/아니오
16		처리하는 개인정보 유형	DID·식별자·지갑주소 등	민감도 판단, 암호화 대상 식별	이름/연락처/지갑주소/KYC/생체정보 등 (대략적)
17		개인정보 처리방침 (최신 버전)	최신 방침·URL 확보 필요	권리행사·파기·블록체인 처리 구조 명시 여부	홈페이지 URL 기재 또는 PDF 파일 제출
18		만 14세 미만 아동 대상 서비스 여부	기업 확인 필요	법정대리인 동의 절차 점검 필요성	예/아니오
19	정보보호 관리체계	정보보호 정책/지침 보유 여부	기업 확인 필요	관리체계 성숙도 파악	예/아니오 (보유 시 문서 명)
20		취약점 점검 수행 여부 (최근 1년)	기업 확인 필요	사전 보안 활동 수준 파악	예/아니오 (수행 시 기관/시기)
21		ISMS/ISO27001 등 인증 보유 여부	기업 확인 필요	기존 보안 수준 참고	인증명/유효기간 (보유 시만)
22		최근 3년 내 보안사고 여부	기업 확인 필요	심층 진단 우선순위	예/아니오 (예인 경우 유형: 계정탈취/스마트컨트랙트/랜섬웨어/개인정보 등)
23		블록체인 보안현황 조사서	서식1 작성본 첨부 운영 정보 확인 필요	점검 범위와 적용 항목 확정	블록체인 점검 범위 확정 / 별도파일 제공
24		점검 대상 목록	서식2 작성본 첨부 실제 주소·대수 확인 필요	배포 주소가 제공되면 온체인 정보는 점검 수행자가 직접 조회	스마트 컨트랙트 (체인, 배포 주소 또는 배포 예정 여부, 용도) - 노드 (직접 운영·위탁·외부 RPC 구분, 대수, 역할) - 지갑 (용도별 분류, 보관 유형) - 온체인 연계 백엔드 서비스
25		블록체인 아키텍처·설계 문서	기술설명서 별첨 A 코드 기반 구성·데이터 분류 기준 승인 설계문서 별도 확인	데이터 분류 기준 확보 및 아키텍처 구성 확인	- 웹·모바일 서비스 및 URL - 보유한 아키텍처 문서 및 구성도 - 온체인·오프체인 데이터 분류 기준 - 설계 시 전제한 가정
26		불변식 및 파라미터 명세	기술설명서 별첨 D	자체 개발 컨트랙트 점검 참고용	- 보유본에 한함 / 신규 작성 불필요 - 지갑·토큰·주소·대수·클러스터 (용도·접근여부·이름·주소)
27		스마트 컨트랙트 소스코드 일체	자체 컨트랙트 소스 미확인 별도 보유·적용 여부 확인 백엔드 기준: 9f31eee	자체 개발 컨트랙트 점검 참고용 - 점검 대상 커밋 해시 또는 태그 - 컴파일러 버전 및 빌드 설정 파일 - 의존성 lockfile - fork한 코드가 있는 경우 원본 저장소 및 버전 - 빌드·테스트 실행 지침 (신규 환경 기준) - 배포 스크립트 및 배포 설정 파일	※ 자체 개발 컨트랙트 보유 시 ※ 점검 범위는 제출 후 협의하여 지정
28		배포 스크립트 및 설정 파일	EC2 배포 예시 확인 기술설명서 별첨 D2 비밀값 제거 원본 별도 확보	배포 계획서 (배포 순서, 초기 파라미터, 검증 절차, 롤백 방안)	※ 자체 개발 컨트랙트 보유 시 ※ 배포 계획서는 배포 전 서비스에 한함 ※ 배포 로그와 트랜잭션 기록은 온체인에서 직접 조회

29	블록체인 점검	권한 구조 문서	서식6 작성본 첨부 운영 직무·인원·승인 확인	- 다중서명 서명자 구성 (직무명 기준) - 각 서명자 키의 보관 유형 - 권한 부여 및 회수 절차 - 임계값과 타임락 설정 근거	※ 자체 개발 컨트랙트 보유 시 ※ 서명자 성명은 요청하지 않음 ※ 권한 보유 주소와 온체인 구성은 직접 조회
30		업그레이드 절차서	업그레이드 구조·절차 확인	- 제안·검토·승인·실행·검증 단계별 절차 - 스토리지 배치 충돌 검증 방식 - 의존 대상 (오라클, 브릿지, 인덱서, 외부 RPC, 지갑 솔루션 등)	※ 업그레이드 가능 구조인 경우 제출 ※ 프록시 구성과 업그레이드 이력은 직접 조회
31		외부 의존성 현황표	서식5 22-26번 기술설명서 별첨 A3	- 운영 주체 - 해당 값이 틀렸을 때 시스템에서 발생하는 결과 - 장애 시 대체 경로 - 노드 설정 파일 (실행 파라미터, RPC 노출 설정, 플러그인·모듈, P2P 설정)	
32		노드 설정 자료	직접 운영 여부 확인 필요 노드 설정·버전 미확인	- 클라이언트 종류 및 버전 - 노드 식별 키와 검증자 키 보관 방식 genesis 또는 chainspec 및 제안 파라미터	※ 노드 직접 운영 시 ※ 민감값을 가린 사본으로 제출 가능
33		폐쇄형·자체 체인 운영 자료	체인 유형·운영범위 확인 genesis·CA 등 별도 확보	- 하드포크·체인 업그레이드 대응 절차 - (허가형) 채널 구성 및 참여 조직 - (허가형) MSP 구성 및 조직별 인증서 발급 체계 - (허가형) CA 운영 현황 - (허가형) 보증 정책 설정 - (허가형) 오더링 서비스 구성 및 합의 방식 - (허가형) 프라이빗 데이터 컬렉션 정의 및 접근 조직 - (허가형) 채널 설정 변경 이력	※ 퍼블릭 체인을 사용하지 않는 경우
34		지갑 구성 자료	서식7 작성본 첨부 운영 주소·관리 주체 확인	- 지갑 시스템 구성도 (하·원·콜드 계층, 서명 경로) - 지갑 및 주소 인벤토리 (용도, 보관 유형, 중요도) - 지갑 솔루션·벤더 정보 및 구성 - 키 생성 절차 (엔드토포리 원천, 생성 환경, 입외 방식, 생성 기록)	※ 잔액과 계층별 보관 비율은 제출된 주소를 기준으로 점검 수행사가 직접 산정
35		키 관리 정책 및 절차서	키 구현: 기술설명서 별첨 C 공식 정책·백업·복구 확인	- 키 보관 방식 (HSM·KMS·MPC 구성, 배포용 키 보관 위치 포함) - 키 백업 및 분산 보관 - 키 복구 절차 및 복구 시험 기록 - 키 교체 주기 및 절차 - 키 폐기 및 매체 와전·사채 절차 - 키 생성 및 관리 환경	※ 하나의 지침으로 관리 중이면 그대로 제출
36		키 사용 및 서명 통제 자료	서식5 33-42번, 별첨 C 분리·승인·한도 정책 확인	- 서명 실행 환경 (전용 단말 여부, 격리 방식) - 서명 정책 설정값 (금액 한도, 화이트리스트, 속도·시간대 제한) - 출금 주소 화이트리스트 등록·변경·해제 승인 절차 - 출금 승인 워크플로 (단계별 권한) - 서명 대상 독립 검증 절차 (서명 화면과 실제 서명 데이터의 대조 방법) - 승인 확인 채널 (금액과 모전지 주소를 확인하는 별도 경로)	
37		키 침해 대응 자료	정책·긴급이전·훈련 확인	- 키 침해 대응 정책 (분류, 대응 계획, 역할, 연락 경로) - 자산 긴급 이전 절차 - 대응 절차 시험 기록 - 액센드·아기락서 및 블록체인 관련 API 목록	※ 배포 전 서비스는 수립 계획으로 같음
38		온체인 연계 백엔드 자료	기술설명서 별첨 A·B 40개 라우트 및 이동 흐름 운영 서명 환경 별도 확인	- 출금 처리 흐름도 (단계별 검증 항목과 실패 시 경로) - 입금 처리 흐름도 (확정 인정 기준, 중복 처리 방지, 재구성 시 롤백) - 출금 트랜잭션을 발생시킬 수 있는 모든 경로 목록 - 트랜잭션 서명 서버 구성 및 격리 방식 - 서명 서버 접근 계정 및 권한 현황 - 서명 요청 거부 조건 - 웨하·코백·스시 검증 방식	※ 소스코드 제출 대신 흐름도로 같음

39	관리자 콘솔 자료	관리자 콘솔·계정 확인	- 접근 경로 및 인증 방식 (다중인증 적용 여부) - 블록체인 기능별 권한 매트릭스 - 해당 권한을 보유한 계정 현황 - 프론트엔드와 앱에 설정된 컨트랙트 주소, 체인 ID, RPC 엔드포인트 목록	
40	프론트엔드·앱 설정 및 서명 화면	test_web-test_script 확인 운영 웹/앱은 별도 확인	- 사용자 서명 요청 화면 및 승인 범위 표시 방식 - 모바일 앱의 개인키 저장 방식 - 감시 대상 주소 및 컨트랙트	※ 이용자 대상 웹·앱을 제공하는 경우 ※ 모바일 항목은 앱이 개인키를 직접 보관하는 경우에 한함
41	온체인 모니터링 구성	파일 로그 구현 확인 온체인 감시·관제 확인	- 이상 징후 탐지 룰과 임계값 - 특권 함수 호출 감시 체계	※ 배포 전 서비스는 구축 계획으로 같음
42	긴급 정지 절차 및 사고 이력	서식5 52-55번 긴급정지·사고 이력 확인	- 알람 발생 시 대응 절차 (담당, 대응 시간) - 출금 중지 절차 (발동 기준, 권한, 승인 절차, 소요 시간) - 컨트랙트 정지 절차 (발동 기준, 권한, 승인 절차, 소요 시간)	※ 사고 이력은 운영 중인 서비스에 한함
43	기존 감사·점검 자료	기업 보유 보고서 확인	- 블록체인 관련 사고·장애 이력 및 대응 기록 - 기존 스마트 컨트랙트 감사 보고서 - 기존 블록체인 관련 보안점검 결과 - 미조치 항목 목록 및 미조치 사유	※ 보유한 경우 제출
44	온체인 잔액과 내부 원장 대사 자료	서식5 56-57번 DB 지급 상태는 수량 아님 대사 정책·실행 기록 확인	- 대조 절차 - 최근 실행 기록 - 불일치 발생 시 처리 절차	※ 결제·정산 서비스를 운영하는 경우
45	증적 표본	운영 증적 표본 별도 확보 요청/승인/서명/거래/원장 이번 작업에서 실거래 없음	- 불일치 발생 시 처리 절차 - 불일치 3~5건의 전체 증적 (요청, 검토, 승인, 서명, 인증, 존재 인 거래해시, 원장 반영) - 입금 1건의 전체 기록 (감지, 확정 대기, 반영, 원장 기록) - 컨트랙트 배포 또는 업그레이드 1~2건의 전체 증적 - 특권 함수 호출 1~2건의 사유·승인·실행 기록 - 블록체인 기능 권한 부여·회수 1건의 이력 - 키퍼더 변경 1건의 지정, 인수인계, 기존 권한 회수 기록 - 모니터링 알람 1건의 발생부터 대응 결과까지 - 전사 1주기의 사전·거주·지급·대조 기록 - 소스코드 저장소 읽기 전용 접근권 (변경 이력 포함) - 테스트넷 배포본 또는 포크 환경 접근 정보	※ 운영 중인 서비스에 한함 ※ 표본은 점검 수행사가 지정 ※ 개인정보는 가린 뒤 제출 가능 ※ 정산 표본은 결제·정산 서비스에 한함
46	점검 환경 및 접근권	서식1 기준 커밋·저장소 접근권·테스트환경 별도 협의		※ 저장소 접근이 어려운 경우 지정 시점 스냅샷으로 대체
47	자료반출 구분표	서식3 분류 제한 첨부 기업 승인 필요	반출 불가한 항목에 대한 대체 확인 방법 협의용	
48	정보시스템 점검 주요 시스템 구성 상세정보(서버/DBMS/웹서비스/ 보안장비/네트워크장비/가상화장비/클라우드)	Flask/Gunicorn-MySQL Linux/EC2 배포 예시 실제 버전·장비·수량 확인	정보 시스템 점검시 스크립트 전달을 위한 목적 (해당 정보 수신 후 49,50,51번 파일 후속 전달 가능)	정보시스템 상세 정보 입력 - Server : Windows/Linux 수량 - DBMS : MSSQL/ORACLE/MYSQL/TIBERO 수량 - 웹 서비스 : Tomcat/JEUS/IIS/Apache/Nginx 수량 - 보안장비 : 방화벽/VPN/IDS/IPS/DDoS/WAF 수량 - 네트워크 : Cisco/Alteon/Juniper/Pioline 수량 - 가상화 장비 : ESXi/vCenter/KVM/Zenserver 수량 - 클라우드 : AWS 등 수량
49	블록체인 관련 정보시스템 스크립트 실행 결과 파 일	점검 스크립트·가이드 수령 후 운영 담당자 실행 필요	정보 시스템 보안 수준 파악	점검용 스크립트 파일 및 가이드 기준
50	네트워크 장비 설정 파일(Config)	장비 설정·마스킹 사본 확인	네트워크 장비 보안 수준 파악	네트워크 장비 내 콘솔을 이용한 Config 설정 내역 저장
51	보안장비 사전 질의 파일	후속 액셀 및 장비 현황 확인	보안장비 운영 보안 수준 파악	엑셀 인터뷰 사전 파일

※ [제출 방식] 안내

- 양식 입력: 본 사이트의 [기업 입력란]에 직접 내용을 기입해 주십시오.
- 별도 제출: 해당 내용을 확인할 수 있는 파일을 이메일에 첨부해 회신해 주십시오.

 ※ 관련 자료가 없을 시 [미보유]로 기입해 주십시오.

※ 기업의 사정으로 인해 미제출 시 불이익은 없으며, 제출된 자료는 현황 및 취약점 진단 목적으로만 사용되며 기밀로 처리됩니다.

서식

1. 블록체인 보안 현황 조사서

□ 작성 안내

○ 본 조사서는 점검 범위와 적용 항목을 확정하기 위한 기초 자료다. 착수 전 단계에 회신한다.

○ 해당 사항이 없는 항목은 해당 없음으로 기재하면 되며 임의로 채울 필요는 없다.

※ 4항의 해당 여부에 따라 제출 대상 산출물이 달라진다.

□ 1. 기업 및 서비스 개요

항목	기재란
기업명	기업 확인 필요 (법인명)
블록체인 서비스명	SOH_DID (프로젝트명, 공식 서비스명 확인 필요)
서비스 상태 (배포 전 / 시범 운영 / 운영 중)	기업 확인 필요 (배포 전/시범/운영 중)
서비스 유형 (예: 결제, 정산, 토큰 발행, NFT, DeFi, 자산 보관)	DID · VC · VP, 체인 지갑 생성, 토큰 생성 · 지급 · 회수 API
사용 체인 및 네트워크	대구체인 DChain/Mitum API, 기본 chain=minic. 운영망 · 체인 유형 확인 필요
서비스 공개 시점 또는 공개 예정 시점	기업 확인 필요
소스코드 공개 여부 (공개 / 비공개)	기업 확인 필요 (저장소 공개 설정)

□ 2. 점검 창구 담당자

○ 자료 요청 및 전달시 필요한 담당자 연락처를 기재한다.

구분	소속	직무	성명	연락처 및 이메일
총괄	기업 확인 필요	기업 확인 필요	기업 확인 필요	기업 확인 필요
대체	기업 확인 필요	기업 확인 필요	기업 확인 필요	기업 확인 필요

□ 3. 점검 대상 시점 및 범위

항목	기재란
소스코드 저장소 주소	https://github.com/hanathomastone/SOH_DID
점검 대상 커밋 해시 또는 태그	9f31eeee2ca7a4261279074fd46859e0e74b2a73e (소스 기준, 문서 기준 239bcbf)
시점 지정일	2026-09-18 (문서 작성 기준, 점검 기준일 협의)
점검 대상에서 제외를 요청하는 범위	확정 없음. 외부 체인 내부·기업 별도 시스템은 범위 협의 필요
제외 요청 사유	본 저장소만으로 외부 운영 구성·권한·노드를 검증할 수 없음

□ 4. 조건부 항목 해당 여부

No.	확인 항목	해당 여부	비고
1	자체 개발한 스마트 컨트랙트를 보유하고 있다	기업 확인 필요	자체 컨트랙트 소스 미확인
2	스마트 컨트랙트가 업그레이드 가능한 구조다	기업 확인 필요	프록시·업그레이드 구현 미확인
3	노드를 직접 운영한다	기업 확인 필요	외부 API 연계 확인
4	퍼블릭 체인이 아닌 폐쇄형 또는 자체 체인을 운영한다	기업 확인 필요	체인 유형 및 운영 주체 확인
5	이용자를 대상으로 하는 웹 또는 모바일 서비스를 제공한다	기업 확인 필요	테스트 웹 있음. 공개 서비스 확인
6	모바일 앱이 개인키를 직접 보관한다	기업 확인 필요	모바일 구현 미확인
7	결제 또는 정산 서비스를 운영한다	기업 확인 필요	영상 토큰 상태 관리

No.	확인 항목	해당 여부	비고
		요	기능 있음
8	지갑, 노드 운영, 키 관리 중 일부를 외부에 위탁한다	기업 확인 필요	DChain 의존. 위탁 계약 확인
9	기존에 받은 스마트 컨트랙트 감사 보고서가 있다	기업 확인 필요	보고서 보유 현황 확인

□ 5. 외부 위탁 및 솔루션 현황

No.	구분	공급사 또는 위탁사	역할과 범위	협조 창구
1	외부 체인 API	대구체인 제공기관 (계약 주체 확인)	계정 생성 · 토큰 · 거래 조회/요청	기업 확인 필요
2	클라우드	AWS EC2 배포 예시	실사용 · 위탁 여부 확인 필요	기업 확인 필요
3	추가 위탁 확인	기업 확인 필요	기업 확인 필요	기업 확인 필요
4	추가 위탁 확인	기업 확인 필요	기업 확인 필요	기업 확인 필요
5	추가 위탁 확인	기업 확인 필요	기업 확인 필요	기업 확인 필요

※ 구분은 지갑 솔루션, 노드 운영 위탁, 키 관리 위탁, 오라클, 브릿지 등으로 기재한다.

소스 기반 후보 목록입니다. 빈 예비행은 미등록이며 실자산 수를 뜻하지 않습니다. 운영 주소·수량은 확인 필요합니다.

□ 작성 안내

- 점검 대상의 수량과 범위를 확정하기 위한 목록이다. 착수 전 단계에 회신한다.
- 배포 주소가 기재되면 온체인에서 확인 가능한 정보는 점검 수행사가 직접 조회한다. 별도로 정리할 필요는 없다.
- ※ 행이 부족하면 표에 행을 추가하여 기재한다.

□ 1. 스마트 컨트랙트

No.	컨트랙트명	체인 및 네트워크	배포 주소	용도	업그레이드 가능 여부
1	DChain 토큰 계약 (실명·수량 확인)	DChain/minic (기본값)	기업 확인 필요 (실배포 주소)	영상별 토큰 지급·회수	확인 필요
2	추가 계약 확인	확인 필요	확인 필요	확인 필요	확인 필요
3	추가 계약 확인	확인 필요	확인 필요	확인 필요	확인 필요
4	추가 계약 확인	확인 필요	확인 필요	확인 필요	확인 필요
5	추가 계약 확인	확인 필요	확인 필요	확인 필요	확인 필요
6	추가 계약 확인	확인 필요	확인 필요	확인 필요	확인 필요
7	추가 계약 확인	확인 필요	확인 필요	확인 필요	확인 필요
8	추가 계약 확인	확인 필요	확인 필요	확인 필요	확인 필요

※ 아직 배포하지 않은 컨트랙트는 배포 주소란에 배포 예정으로 기재한다. 업그레이드 가능 여부는 프록시 등으로 구현을 교체할 수 있는 구조인지를 가능 또는 불가로 기재한다.

□ 2. 노드

No.	식별명	체인	운영 형태	클라이언트 및 버전	대수	역할
1	DChain API 연계	DChain	외부 RPC 사용 에 준하는 HTTPS API	운영기관 확인	미확인	체인 조회 · 변경 요청
2	직접/위탁 노드 확인	확인 필요	기업 확인 필요	확인 필요	미확인	확인 필요
3						
4						
5						
6						

※ 운영 형태는 직접 운영, 위탁 운영, 외부 RPC 사용 중 하나로 기재한다.

□ 3. 지갑

No.	지갑명	용도	보관 유형	서명 방식	관리 주체
1	서버 소유자 지갑	발행 · 지급 · 회수	서버 온라인 사용, 핫 추정	개인키 1개 전달; 체인 방식 확인	기업 확인 필요
2	서버 키 보관 사용자 지갑군	보상 수령 · 레거시 회수	서버 파일, 핫 추정	개인키 1개 전달; 체인 방식 확인	기업 확인 필요
3	DID 서명 키 (참고)	VC/VP Ed25519 서명	파일 및 DB	로컬 단일키 서명	서비스 운영 직무 확인
4					
5					
6					
7					
8					

※ 보관 유형은 핫, 워, 콜드로 구분하고 서명 방식은 단일서명, 다중서명, MPC 중 하나로 기재한다.

□ 4. 온체인 연계 백엔드 서비스

No.	서비스명	역할	블록체인 연동 방식	서명 서버 사용 여부
1	SOH_DID Flask API	DID · 토큰 · 체인 조회/변경	DChain HTTPS API	체인 키를 외부 API에 전달; 전용 서버 여부 미확인
2	MySQL 연계부	DID/user/Token/keyValue 저장	API 결과를 로컬 DB 반영	자체 체인 서명 기능 미확인
3	로컬 DID 키 저장소	DID/VC/VP 서명 · 레거시 회수	키 파일 조회	VC/VP는 Flask 프로세스에서 서명
4				
5				
6				

□ 5. 웹 및 모바일 서비스

No.	서비스명	URL 또는 스토어 주소	지갑 연동 여부
1	테스트 웹	test_web.html, test_script.js; API http://127.0.0.1:5000	서버 API를 통한 지갑 생성 · 토큰 지급
2	이용자 운영 웹/모바일	기업 확인 필요	공개 운영 · 모바일 여부 확인
3			
4			
5			

모든 분류는 기업 승인 전 제안입니다. 조건부는 반출 승인이나 자료 보유를 의미하지 않습니다. 비밀번호·토큰·비밀번호 원문은 포함하지 않습니다.

□ 작성 안내

- 제출이 어려운 자료를 착수 전에 미리 구분하기 위한 표다. 반출이 불가능한 항목은 대체 확인 방법을 협의한다.
- 반출 구분은 가능, 조건부, 불가 중 하나로 기재한다. 조건부는 마스킹, 열람 방식 제한 등 조건을 붙여 제출할 수 있는 경우를 말한다.

※ 대체 확인 방법이 없는 항목은 점검 결과보고서에 확인 불가 영역으로 기재된다.

No.	산출물 명	반출 구분	사유	대체 확인 방법
1	회사소개서 또는 서비스 소개서	조건부	기업 승인 전 제안. 비밀번호·개인정보 제거 후 제공	담당자 승인 후 마스킹 사본 또는 현장 열람
2	점검 대상 목록	조건부	기업 승인 전 제안. 비밀번호·개인정보 제거 후 제공	담당자 승인 후 마스킹 사본 또는 현장 열람
3	블록체인 아키텍처·설계 문서	조건부	기업 승인 전 제안. 비밀번호·개인정보 제거 후 제공	담당자 승인 후 마스킹 사본 또는 현장 열람
4	불변식 및 파라미터 명세	조건부	기업 승인 전 제안. 비밀번호·개인정보 제거 후 제공	담당자 승인 후 마스킹 사본 또는 현장 열람
5	스마트 컨트랙트 소스코드 일체	조건부	보유·적용 여부 미확인. 확보 및 승인 필요	담당자 승인 후 마스킹 사본 또는 현장 열람
6	배포 스크립트 및 설정 파일	조건부	기업 승인 전 제안. 비밀번호·개인정보 제거 후 제공	비밀키·토큰·비밀번호 원문 제외. 설정 구조·마스킹 증적 확인
7	권한 구조 문서	조건부	기업 승인 전 제안. 비밀번호·개인정보 제거 후 제공	담당자 승인 후 마스킹 사본 또는 현장 열람
8	업그레이드 절차서	조건부	보유·적용 여부 미확인. 확보 및 승인 필요	담당자 승인 후 마스킹 사본 또는 현장 열람
9	외부 의존성 현황표	조건부	기업 승인 전 제안. 비	담당자 승인 후 마스

No.	산출물 명	반출 구분	사유	대체 확인 방법
			밀값·개인정보 제거 후 제공	킹 사본 또는 현장 열람
10	노드 설정 자료	조건부	보유·적용 여부 미확인. 확보 및 승인 필요	담당자 승인 후 마스크 사본 또는 현장 열람
11	폐쇄형·자체 체인 운영 자료	조건부	보유·적용 여부 미확인. 확보 및 승인 필요	담당자 승인 후 마스크 사본 또는 현장 열람
12	지갑 구성 자료	조건부	기업 승인 전 제안. 비밀값·개인정보 제거 후 제공	비밀키·토큰·비밀번호 원문 제외. 설정 구조·마스킹 증적 확인
13	키 관리 정책 및 절차서	조건부	기업 승인 전 제안. 비밀값·개인정보 제거 후 제공	비밀키·토큰·비밀번호 원문 제외. 설정 구조·마스킹 증적 확인
14	키 사용 및 서명 통제 자료	조건부	기업 승인 전 제안. 비밀값·개인정보 제거 후 제공	비밀키·토큰·비밀번호 원문 제외. 설정 구조·마스킹 증적 확인
15	키 침해 대응 자료	조건부	보유·적용 여부 미확인. 확보 및 승인 필요	담당자 승인 후 마스크 사본 또는 현장 열람
16	온체인 연계 백엔드 자료	조건부	기업 승인 전 제안. 비밀값·개인정보 제거 후 제공	담당자 승인 후 마스크 사본 또는 현장 열람
17	관리자 콘솔 자료	조건부	보유·적용 여부 미확인. 확보 및 승인 필요	담당자 승인 후 마스크 사본 또는 현장 열람
18	프론트엔드·앱 설정 및 서명 화면	조건부	기업 승인 전 제안. 비밀값·개인정보 제거 후 제공	담당자 승인 후 마스크 사본 또는 현장 열람
19	온체인 모니터링 구성	조건부	기업 승인 전 제안. 비밀값·개인정보 제거 후 제공	담당자 승인 후 마스크 사본 또는 현장 열람
20	긴급 정지 절차 및 사고 이력	조건부	기업 승인 전 제안. 비밀값·개인정보 제거 후 제공	담당자 승인 후 마스크 사본 또는 현장 열람
21	기존 감사·점검 자료	조건부	보유·적용 여부 미확인. 확보 및 승인 필요	담당자 승인 후 마스크 사본 또는 현장 열람
22	온체인 잔액과 내부 원장 대사 자료	조건부	기업 승인 전 제안. 비밀값·개인정보 제거 후 제공	담당자 승인 후 마스크 사본 또는 현장 열람
23	증적 표본	조건부	보유·적용 여부 미확인. 확보 및 승인 필요	비밀키·토큰·비밀번호 원문 제외. 설정 구조·마스킹 증적

No.	산출물 명	반출 구분	사유	대체 확인 방법
				확인
24	점검 환경 및 접근권	조건부	원본 소스에 민감 기본값 포함. 접근 범위 승인 필요	비밀값 제거 지정 커밋 사본 또는 제한된 현장 열람

제출 상태는 이 작성 묶음에 포함할 자료 기준이며 외부 제출 완료란 뜻하지 않습니다. 확인 필요는 임시 상태입니다. 기업 확인 후 원본의 4개 상태 중 하나로 확정해야 합니다.

□ 작성 안내

○ 제출 자료를 취합해 회신하는 점검표다. 사전 준비 단계에 제출 자료와 함께 회신한다.

○ 제출 여부는 제출, 일부 제출, 미보유, 해당 없음 중 하나로 기재한다.

※ 미보유와 해당 없음은 결함이 아니다. 서비스 상태와 구성에 따라 자연스럽게 발생한다.

No.	산출물 명	제출 여부	파일명	비고
1	회사소개서 또는 서비스 소개서	일부 제출	서식1; 기술설명서 7번	작성 자료 포함 예정, 외부 제출 전. 실제 운영 증적은 별도 확인
2	점검 대상 목록	일부 제출	서식2	작성 자료 포함 예정, 외부 제출 전. 실제 운영 증적은 별도 확인
3	블록체인 아키텍처·설계 문서	일부 제출	기술설명서 별첨 A	작성 자료 포함 예정, 외부 제출 전. 실제 운영 증적은 별도 확인
4	불변식 및 파라미터 명세	일부 제출	기술설명서 별첨 D	작성 자료 포함 예정, 외부 제출 전. 실제 운영 증적은 별도 확인
5	스마트 컨트랙트 소스코드 일체	확인 필요	-	보유 여부·적용 여부 확인 후 제출/미보유/해당 없음 확정
6	배포 스크립트 및 설정 파일	일부 제출	기술설명서 별첨 D2	설정 설명만 포함. 원본 설정파일은 비밀값 제

No.	산출물 명	제출 여부	파일명	비고
				거 후 별도 제출
7	권한 구조 문서	일부 제출	서식6	작성 자료 포함 예정, 외부 제출 전, 실제 운영 증적은 별도 확 인
8	업그레이드 절차서	확인 필요	-	보유 여부·적용 여부 확인 후 제 출/미보유/해당 없음 확정
9	외부 의존성 현황표	일부 제출	서식5 22-26번; 별첨 A3	작성 자료 포함 예정, 외부 제출 전, 실제 운영 증적은 별도 확 인
10	노드 설정 자료	확인 필요	-	보유 여부·적용 여부 확인 후 제 출/미보유/해당 없음 확정
11	폐쇄형·자체 체인 운영 자료	확인 필요	-	보유 여부·적용 여부 확인 후 제 출/미보유/해당 없음 확정
12	지갑 구성 자료	일부 제출	서식7; 별첨 C	작성 자료 포함 예정, 외부 제출 전, 실제 운영 증적은 별도 확 인
13	키 관리 정책 및 절차서	일부 제출	기술설명서 별첨 C	작성 자료 포함 예정, 외부 제출 전, 실제 운영 증적은 별도 확 인
14	키 사용 및 서명 통제 자료	일부 제출	서식5 33-42번; 별첨 C	작성 자료 포함 예정, 외부 제출 전, 실제 운영 증적은 별도 확 인
15	키 침해 대응 자료	확인 필요	-	보유 여부·적용 여부 확인 후 제 출/미보유/해당 없음 확정
16	온체인 연계 백엔드 자료	일부 제출	기술설명서 별첨 A·B	작성 자료 포함 예정, 외부 제출 전, 실제 운영 증적은 별도 확

No.	산출물 명	제출 여부	파일명	비고
				인
17	관리자 콘솔 자료	확인 필요	-	보유 여부·적용 여부 확인 후 제 출/미보유/해당 없음 확정
18	프론트엔드.앱 설정 및 서명 화면	일부 제출	기술설명서 40번	작성 자료 포함 예정, 외부 제출 전, 실제 운영 증적은 별도 확 인
19	온체인 모니터링 구성	일부 제출	기술설명서 41번	작성 자료 포함 예정, 외부 제출 전, 실제 운영 증적은 별도 확 인
20	긴급 정지 절차 및 사고 이력	일부 제출	서식5 52-55번	질의 회신만 포 함. 승인 절차 서·사고 이력은 확인 필요
21	기존 감사·점검 자료	확인 필요	-	보유 여부·적용 여부 확인 후 제 출/미보유/해당 없음 확정
22	온체인 잔액과 내부 원장 대사 자료	일부 제출	서식5 56-57번	작성 자료 포함 예정, 외부 제출 전, 실제 운영 증적은 별도 확 인
23	증적 표본	확인 필요	-	보유 여부·적용 여부 확인 후 제 출/미보유/해당 없음 확정
24	점검 환경 및 접근권	일부 제출	서식1 3항; 기술설명 서 46번	저장소 위치·기 준만 기재. 접근 권 부여·테스트 환경 제공 미실 시

작성일 2026-09-18. 58개 문항 회신. 코드에서 확인되는 동작과 기업 확인 사항을 구분했습니다. 별첨은 SOH_DID_기술설명서.pdf를 뜻합니다.

□ 작성 안내

- 해당 업무를 수행하는 인력이나 절차가 없는 경우 해당 없음으로 회신하면 된다. 그 자체가 점검 결과로 반영된다.
 - 제출 자료에 이미 기재된 내용은 자료명과 위치를 적는 것으로 같음할 수 있다.
- ※ 총 58개 문항이며 각 분류의 괄호 안은 대응하는 사전 요청자료 번호다.

□ 1. 설계 의도와 전제

No.	질의 항목	회신
1	온체인에 둔 데이터와 오프체인에 둔 데이터를 나눈 기준은 무엇입니까.	코드상 계정·토큰 거래는 DChain으로 요청하고 DID 문서·키·사용자 지급 상태·토큰 메타데이터는 파일/DB에 둡니다. DID 자체는 로컬 did:key이며 체인 등록과 다릅니다. 설계 당시 분류 기준은 담당자 확인 필요. [별첨 A2]
2	설계 시 신뢰할 수 있다고 전제한 주체는 누구입니까. 그 주체가 악의적으로 행동하면 어떤 결과가 발생합니까.	DChain API, Flask 실행환경, 로컬 키 파일 및 MySQL을 신뢰하는 구조입니다. 이들이 침해되면 거래 요청·서명키·지급 상태가 변조될 수 있습니다. 공식 신뢰 가정·통제는 확인 필요. [별첨 A3·C]
3	시스템 전체에서 항상 참이어야 하는 조건은 무엇입니까. 그 조건이 깨진 것을 무엇으로 알 수 있습니까.	공식 불변식은 미확인입니다. 구현은 일부 DB 갱신에 HTTP 200 및 state=OK를 요구하지만 온체인 잔액과 DB 상태의 일치를 보장하지 않습니다. 독립 대사·불변식 감시 로직은 미확인. [별첨 B2·D1]
4	주요 파라미터의 현재 값을 그 값으로 정한 근거는 무엇입니까.	기본값은 chain=minic, DChain timeout 20초, token decimals 9, VC TTL 3600초, VP TTL 300초입니다. 운영값과 값 선정 근거는 별도 확인 필요. [별첨 D1]
5	파라미터가 어떤 범위를 벗어나면 위험하다고 판단합니까. 그 범위를 코드에서 강제하고 있습니까.	전송 token_name은 허용된 영상 토큰 12종으로 제한합니다. amount의 양수·상한과 TTL의 양수·상한에 대한 공통 검사는 미확인입니다. 업무상 위험 임계값은 기업

No.	질의 항목	회신
		확인 필요. [별첨 D1]
6	산술 계산에서 반올림 방향과 정밀도를 어떻게 정했습니까. 절삭으로 남는 잔여분은 어디로 귀속됩니까.	토큰 생성 decimals 기본값은 9이며 체인 계산은 외부 API에 의존합니다. 백엔드 지급 상태는 수량을 누적하지 않고 1로 기록합니다. 온체인 반올림 · 잔여분 귀속 정책은 운영기관 확인 필요. [USER_db.py]
7	수수료, 이자, 보상 산정식은 문서와 코드 중 무엇을 기준으로 관리합니까. 둘이 다를 경우 무엇이 우선합니까.	영상 토큰 지급 경로에 amount 기본값 1이 있습니다. 수수료 · 이자 · 보상 산정 공식 및 문서/코드 우선순위 정책은 저장소에서 미확인입니다. 서비스 담당자 확인 필요.

□ 2. 스마트 컨트랙트와 배포

No.	질의 항목	회신
8	점검 대상으로 지정한 시점 이후 배포 전까지 코드 변경 계획이 있습니까.	이번 문서 기준 소스는 9f31eee입니다. 이번 작업은 문서만 작성하며 이후 배포 전 코드 변경 계획은 개발·배포 담당자가 확정해야 합니다.
9	외부 저장소에서 가져와 수정한 코드가 있습니까. 있다면 원본 대비 무엇을 바꾸었고 그 이유는 무엇입니까.	PyMySQL 1.1.1 vendor 포함은 확인됩니다. 자체 컨트랙트 fork 원본·버전·변경 내역은 미확인입니다. 오픈소스 구성과 수정 이력은 개발 담당자 확인 필요.
10	배포 시 초기 파라미터를 누가 정하고 누가 검증합니까.	환경변수와 일부 코드 기본값으로 초기값을 설정합니다. 값을 정하는 직무, 독립 검증자와 승인 기록은 미확인입니다. 자체 컨트랙트 배포 절차 적용 여부도 확인 필요.
11	배포 직후 수행하는 검증 절차가 있습니까. 무엇을 확인합니까.	회수 API 테스트 코드와 EC2 서비스 예시는 있습니다. 실제 배포 직후 점검 목록, 실행 기록 및 승인 기준은 미확인입니다. 테스트 코드를 배포 검증 완료 증적으로 간주하지 않습니다.
12	배포가 잘못되었을 때 되돌리는 방법은 무엇입니까.	배포 롤백 및 온체인 거래 보상 절차는 미확인입니다. DID DB 저장 rollback은 이미 생성된 체인 지갑·파일을 취소하지 않습니다. 코드 롤백과 자산 복구는 구분해 확인해야 합니다.
13	테스트가 다루지 못한다고 이미 알고 있는 영역이 있습니까.	회수 테스트 코드만 정적으로 검토했으며 이번엔 실행하지 않았습니다. 운영 체인·DB, 외부 서명, 장애 후 보상, 다중 프로세스 파일 경합의 검증 기록은 미확인입니다. 기업이 인지한 미검증 범위는 별도 확인 필요.

□ 3. 권한과 업그레이드

No.	질의 항목	회신
14	배포 이후에도 남아 있는 특권 권한은 무엇이며 남겨 둔 이유는 무엇입니까.	서버 소유자 설정은 토큰 생성·mint 및 전송 기본값, 회수 권한 비교에 쓰입니다. 실제 온체인 권한과 유지 사유는 확인 필요합니다. 공통 호출자 인증·역할 통제는 라우트에서 미확인. [서식6]
15	다중서명 임계값을 현재 값으로 정한 근거는 무엇입니까.	다중서명 구현과 임계값은 저장소에서 미확인입니다. 체인 또는 별도 운영 솔루션의 적용 여부 및 근거를 확인해야 하며 임계

No.	질의 항목	회신
		값을 임의로 기재하지 않습니다.
16	서명자 중 몇 명이 동시에 연락 두절되면 운영이 멈추니까.	서명자 직무·인원·다중서명 임계값이 미확인이라 중단 인원을 산정할 수 없습니다. 서버 키 의존 경로는 있으나 운영 대체 담당·복구 가능성은 별도 확인 필요.
17	서명자 키가 서로 다른 매체와 장소에 보관되어 있습니까. 한 사람이 둘 이상의 키를 보관하는 경우가 있습니까.	DID 키는 파일과 DB, 사용자 체인 키는 로컬 키 파일, 소유자 키는 서버 설정에 사용됩니다. 서명자별 매체·장소 분리 및 1인 복수 키 보관 여부는 기업 확인 필요.
18	타임락을 설정했다면 그 시간 동안 무엇을 하기로 되어 있습니까. 실제로 그 절차를 수행한 적이 있습니까.	타임락 설정 및 대기 중 검증·취소 절차와 수행 기록은 저장소에서 미확인입니다. 외부 체인 설정과 별도 운영 절차의 존재 여부를 확인해야 합니다.
19	권한 보유자가 퇴사하거나 직무가 바뀔 때 권한 회수는 어떤 절차로 이루어집니까.	퇴사·직무 변경 시 권한 회수 절차와 이력은 기업 확인 필요합니다. /did/delete는 파일과 인덱스를 삭제하며 DID/user DB 행·백업·기전달 키 회수까지 수행하지 않습니다.
20	업그레이드 시 스토리지 배치 충돌을 어떤 방법으로 확인합니까.	자체 업그레이드 컨트랙트·스토리지 레이아웃과 충돌 검사 도구는 미확인입니다. 적용 구조를 확인한 후 배포 담당자가 검증 방법·기록을 제출해야 합니다.
21	긴급 상황에서 정해진 절차를 생략하고 업그레이드할 수 있는 경로가 있습니까.	정상·긴급 업그레이드 절차와 우회 실행 경로는 미확인입니다. 별도 컨트랙트 관리자·배포 계정의 실제 권한 및 비상 승인 체계 확인이 필요합니다.

□ 4. 외부 의존성

No.	질의 항목	회신
22	각 외부 대상이 잘못된 값을 반환하면 시스템에서 어떤 결과가 발생합니까.	DChain 오류 값은 계정 주소 · 토큰 메타데이터 · 거래 성공 판정에 영향을 줍니다. MySQL 불일치는 주소 조회 · 지급 상태에, 키 파일 오류는 서명 · 회수에 영향을 줍니다. 운영 주체는 DChain 제공기관 및 기업 운영 담당 확인 필요. [별첨 A3]
23	외부 대상의 값이 정상 범위를 벗어났는지 검증하는 로직이 있습니까.	DID 계정 생성에서 주소 존재 여부, 일부 거래 후 HTTP 200/state=OK 및 token_name 허용 목록을 검사합니다. 외부 가격 · 잔액 · 금액 전반의 범위 및 독립 검증은 미확인입니다.
24	외부 대상이 응답하지 않을 때 시스템은 멈추니까, 아니면 마지막 값을 계속 사용합니까.	기본 20초 timeout 시 504, 연결 · 요청 오류 시 502를 반환합니다. 마지막 성공값으로 거래를 계속하는 fallback, 대체 RPC 또는 재시도 큐는 미확인입니다. DB는 연결 재확인 · 재접속을 시도합니다.
25	외부 대상의 운영 주체가 값을 임의로 바꿀 수 있습니까. 그 경우 대응 수단이 있습니까.	외부 운영기관의 값 변경 권한과 운영 통제는 본 저장소로 검증할 수 없습니다. 독립 노드 대조 · 응답 무결성 검증 · 공급사 대응 약정은 기업 및 제공기관 확인 필요.
26	브릿지를 사용한다면 양쪽 체인의 자산 수량이 일치하는지 무엇으로 확인합니까.	브릿지 연계 구현은 이 저장소에서 미확인입니다. 서비스 전체의 사용 여부를 확인한 후 미사용이면 해당 없음으로 확정하며, 사용 시 양 체인 대사 자료가 필요합니다.

□ 5. 노드와 체인 운영

No.	질의 항목	회신
27	노드의 RPC 를 외부에 공개하고 있습니까. 공개한다면 어떤 메서드까지 허용합니까.	외부 DChain HTTPS API를 호출합니다. 자체 노드 RPC 공개 설정은 미확인입니다. 앱에는 조회 및 자산 변경 프록시가 있으므로 운영 URL · 인증 · 네트워크 허용 범위는 별도 확인 필요.
28	트랜잭션을 몇 블록 확정 후 최종으로 인정합니까. 그 수를 정한 근거는 무엇입니까.	일부 거래 성공은 HTTP 200/state=OK로 판단합니다. 독립적인 확정 블록 수 기준은 미확인입니다. DChain 응답의 최종성 의미와 운영 기준을 제공기관에 확인해야 합니다.
29	체인 재구성이 발생한 경우 어떻게 인지하고 무엇을 되돌립니까.	체인 재구성 감지, 입금 상태 롤백 및 재처리 로직은 저장소에서 미확인입니다. 외부

No.	질의 항목	회신
		체인의 최종성과 서비스의 대응 책임·절차를 확인해야 합니다.
30	노드 클라이언트 버전 업그레이드와 하드포크 대응은 누가 판단하고 언제 적용합니까.	노드 직접 운영 여부와 클라이언트 버전은 미확인입니다. 노드 업그레이드·하드포크 판단 주체, 일정 및 검증 기준은 기업/체인 운영기관 확인 필요.
31	허가형 체인을 운영한다면 채널 또는 조직을 추가하거나 제거하는 결정은 누가 승인합니까.	체인 유형과 직접 운영 범위가 확정되지 않았습니다. 허가형 채널·조직 변경 설정 및 승인자는 미확인이므로 적용 여부부터 확인해야 합니다.
32	허가형 체인을 운영한다면 인증서 폐기가 필요할 때 어떤 절차로 처리합니까.	허가형 체인의 CA/MSP 및 인증서 폐기 절차는 미확인입니다. 로컬 did:key 파일 삭제는 체인 인증서 폐기 절차를 대신하지 않습니다.

□ 6. 키 관리와 서명 통제

No.	질의 항목	회신
33	키를 생성할 때 사용한 난수 원천은 무엇입니까. 생성 과정을 기록으로 남겼습니까.	DID 키는 cryptography의 <code>Ed25519PrivateKey.generate()</code> 로 생성해 라이브러리에 난수 생성을 위임합니다. 체인 키는 DChain 계정 생성 응답으로 받습니다. 입회·생성 기록·외부 난수 원천은 미확인.
34	키가 평문으로 존재하는 순간이 있습니까. 있다면 어디입니까.	키는 Flask 메모리, 로컬 JSON 및 DID 개인키 DB 필드에 평문으로 존재합니다. DID 생성 응답에는 개인키와 wallet 객체가 포함되고 체인 요청에 키를 전달합니다. 테스트 웹 출력에도 노출 가능. [별첨 C2]
35	개발자 개인 단말에 배포용 키가 남아 있는 경우가 있습니까.	소유자 키 등의 민감 기본값이 소스에 포함됩니다. 개발자 단말·배포본·이력·백업에 남은 사본 여부는 기업 확인 필요합니다. 본 제출 문서에는 비밀값을 수록하지 않았습니다.
36	키 백업본은 몇 부가 어디에 있으며 누가 접근할 수 있습니까.	키 백업본의 수량, 장소, 접근 직무·인원과 분산 보관 절차는 저장소에서 미확인입니다. 실제 백업 자산 목록과 접근 기록을 기업이 확인해야 합니다.
37	복구 절차를 실제로 시험해 본 적이 있습니까. 언제 수행했고 결과는 어땠습니까.	키 복구 시험 일자·절차·결과 증적은 미확인입니다. 기업 보유 시험 보고서와 복구 담당자 확인이 필요하며 미실시로 단정하지 않습니다.
38	키를 교체한 적이 있습니까. 교체 시 기존 키는 어떻게 처리합니까.	교체 이력·주기·폐기 정책은 기업 확인 필요합니다. <code>/did/delete</code> 는 파일 unlink와 인덱스 삭제만 수행하고 DB 및 백업의 키 폐기·매체 완전삭제는 수행하지 않습니다.
39	서명 요청이 정당한지 누가 어떻게 확인합니까. 요청자와 승인자가 분리되어 있습니까.	<code>/token/retrieve</code> 는 송수신 주소와 소유자 키를 비교합니다. 이는 사람의 분리 승인·MFA가 아닙니다. 공통 요청자/승인자 분리와 역할 인증은 미확인입니다. 직접 <code>transfer_from</code> 에는 이 비교가 적용되지 않습니다.
40	서명 대상 데이터를 서명 화면과 다른 경로로 대조하는 절차가 있습니까.	테스트 웹은 응답을 화면·콘솔에 출력합니다. 독립 채널에서 금액·목적지·서명 데이터를 대조하는 절차와 전용 서명 화면은 미확인입니다. 운영 절차 확인 필요.
41	화이트리스트에 없는 주소로 출금해야 할 때 어떤 절차를 거칩니까. 실제 사례가 있습니까.	일반 출금 주소 화이트리스트와 예외 승인 절차·실제 사례는 미확인입니다. <code>retrieve</code> 의 소유자 주소 비교를 서비스 전반의 출금 화이트리스트로 보지 않습니다.
42	키가 유출되었다고 판단하는 기준은	키 유출 판단 기준, 첫 조치, 담당 직무와

No.	질의 항목	회신
	무엇입니까. 판단 후 첫 조치는 무엇이며 몇 분 안에 가능합니까.	대응 시간은 기업 확인 필요합니다. 긴급 자산 이전 · 키 교체 · 연락망 및 훈련 증적은 저장소에서 미확인입니다.

□ 7. 온체인 연계 백엔드와 관리자 콘솔

No.	질의 항목	회신
43	출금 트랜잭션을 발생시킬 수 있는 경로를 전부 나열하면 무엇입니까.	자산 이동 요청: /token/transfer, /token/transfer_from, /token/retrieve, /common/cur_transfer. 승인 · 공급 변경: token/create · approve · mint · burn. acc_create · acc_faucet · DID 생성 · upload_token도 체인 변경 여부 확인 대상입니다. [별첨 B4]
44	정상 경로 외에 운영자 수동 실행이나 배치 작업으로 출금이 발생하는 경우가 있습니까.	공개된 프록시 API를 직접 호출할 수 있는 경로는 있습니다. 운영자 수동 호출, 별도 배치 · 관리 도구의 존재와 권한은 저장소만으로 확인할 수 없어 추가 확인 필요합니다.
45	같은 출금 요청이 두 번 처리되는 것을 무엇으로 막습니까.	출금 요청 식별자에 의한 멍등성 · 중복 거래 차단은 해당 라우트에서 미확인입니다. DB 상태를 1로 덮어쓰는 동작은 반복 온체인 전송 자체를 방지하지 않습니다.
46	입금을 확정으로 인정하는 기준은 무엇입니까. 확정 전에 사용자에게 잔액을 반영합니까.	입금 watcher, 확정 대기 · 반영 및 재구성 롤백 로직은 미확인입니다. 잔액 조회 API는 있으나 내부 user 필드는 지급 상태입니다. 실제 입금 확정 및 선반영 정책은 기업 확인 필요.
47	서명 서버에 접근할 수 있는 계정은 몇 개이며 누구입니까. 사람이 직접 접속할 수 있습니까.	VC/VP는 Flask 프로세스에서 서명하고 체인 키는 외부 DChain API로 전달합니다. 전용 서명 서버 구성, 접근 계정 수 · 직무 및 사람의 직접 접속 가능 여부는 미확인입니다.
48	서명 서버가 서명 요청을 거부하는 조건이 있습니까.	retrieve 주소/키 불일치 시 403, 전송의 잘못된 token_name은 400, 미등록 DID는 404, 계약 조회 실패는 400입니다. 레거시 approve 실패 시 회수 전송을 중단합니다. 외부 서명 서버 거부 정책은 확인 필요.
49	관리자 콘솔에서 블록체인 관련 기능을 실행할 때 추가 승인을 요구합니까.	별도 관리자 콘솔 및 추가 승인 · MFA 흐름은 저장소에서 미확인입니다. 테스트 웹을 운영 관리자 콘솔로 단정하지 않으며 실제 관리자 계정 · 기능별 승인은 기업 확인 필요.

□ 8. 이용자 대상 구간

No.	질의 항목	회신
50	프론트엔드와 앱에 들어가는 컨트랙트 주소와 RPC 엔드포인트를 누가 어떤 절차로 변경합니까.	테스트 웹은 로컬 API 주소를 사용하고 서버의 DCHAIN 환경 설정 및 토큰 DB가 연계 값에 관여합니다. 변경 직무·검토·승인·배포 절차는 미확인입니다. [별첨 D2]
51	사용자에게 서명을 요청할 때 승인 범위를 어떻게 표시합니까. 무제한 승인을 요청하는 경우가 있습니까.	사용자 서명 승인 화면은 미확인입니다. 레거시 회수 내부 approve는 요청 수량으로 호출하며 일반 /token/approve는 프록시입니다. 서비스 전체의 무제한 승인 요청 여부는 별도 확인 필요.

□ 9. 모니터링과 긴급 대응

No.	질의 항목	회신
52	특권 함수가 호출되면 몇 분 안에 인지할 수 있습니까. 야간과 휴일에도 동일합니까.	파일 로그는 있으나 특권 함수 감시·알림 및 야간/휴일 관제 증적은 미확인입니다. 인지 시간과 24x7 대응 수준은 기업 확인 필요합니다.
53	출금을 즉시 중지할 권한을 가진 사람은 누구이며 중지까지 몇 분이 걸립니까.	전용 출금 중지 스위치와 컨트랙트 pause 연계는 미확인입니다. OS 서비스 중지 권한자·승인·소요 시간은 확인 필요하며 앱 중지가 이미 제출된 체인 거래를 취소하지는 않습니다.
54	이상 징후 임계값을 정한 근거는 무엇입니까. 오탐이 많아 알람을 끈 사례가 있습니까.	이상 징후 룰·임계값·설정 근거와 오탐으로 알람을 끈 사례는 기업 확인 필요합니다. 로그 로테이션 1MB/10개는 이상거래 탐지 임계값에 해당하지 않습니다.
55	블록체인 관련 사고나 장애가 있었다면 원인과 재발 방지 조치는 무엇입니까.	보안사고·블록체인 장애의 발생 여부, 원인과 재발 방지 기록은 기업 확인 필요합니다. 저장소에 사고 기록이 없다는 이유로 무사고로 답변하지 않습니다.

□ 10. 잔액 대조와 기존 점검

No.	질의 항목	회신
56	온체인 잔액과 내부 원장을 얼마나 자주 대조합니까. 누가 수행하고 누가 확인합니까.	정기 대사 주기와 수행·검토 직무는 미확인입니다. 잔액 조회는 가능하나 user 토큰

No.	질의 항목	회신
		필드는 수량 원장이 아니라 지금 상태 1입니다. 회수 시 차감/초기화도 없어 독립 원장 확인이 필요합니다.
57	대조 결과가 맞지 않은 적이 있습니까. 원인은 무엇이었습니까.	실제 대사 불일치 이력과 원인은 기업 확인 필요합니다. 구조상 온체인 성공 후 DB 실패·반복 전송·회수 미반영 시 상태 차이가 생길 수 있으나 실제 발생을 검증한 것은 아닙니다.
58	기존 감사에서 지적된 항목 중 조치하지 않은 것이 있습니까. 조치하지 않은 이유는 무엇입니까.	기존 감사 보고서·미조치 목록 및 사유는 기업 확인 필요합니다. 저장소 테스트 코드와 이번 기술 설명서는 외부 감사나 조치 완료 증적을 대체하지 않습니다.

6. 권한 인벤토리 매트릭스

보유 주체 · 인원 · 승인은 기업 확인 필요입니다. 아래 행은 코드상 키 사용 · 기능 경로이며 승인된 온체인 권한표가 아닙니다. 성명 · 주소는 기재하지 않았습니다.

□ 작성 안내

○ 블록체인 기능에 영향을 주는 권한만 기재한다. 일반 업무 시스템의 계정 권한은 대상이 아니다.

○ 보유 주체는 직무명으로 기재한다. 성명과 주소는 기재하지 않는다.

※ 권한 보유 주소와 온체인 권한 구성은 점검 수행사가 직접 조회한다.

□ 1. 온체인 특권 권한

No.	권한 또는 역할명	적용 대상	수행 가능 행위	보유 주체	인원	승인 절차
1	서버 소유자 키	DChain 토큰 API	생성 · mint · 기본 전송 · 회수 요청	운영 직무 확인	미확인	키 설정 사용; 사람 승인 미확인
2	지갑 holder 키	레거시 회수 승인	요청 수량 allowance 승인	키관리 직무 확인	미확인	retrieve 내 소유자 비교
3	컨트랙트 특권 역할	실제 배포 계약	체인 역할 · 권한은 운영 기관 확인	기업 확인	미확인	기업 확인
4						
5						
6						
7						
8						

□ 2. 관리자 콘솔 및 서명 서버 권한

No.	권한 또는 역할 명	적용 대상	수행 가능 행위	보유 주체	인원	승인 절차
1	API 호출 권한	Flask 라우트	DID · 토큰 · 공통 API 요청	호출 직무 확인	미확인	공통 사용자 인증 · RBAC 미확인
2	DID 서명키 접근	Flask/로컬 파일	VC · VP 서명, 키 파일 조회	운영 직무 확인	미확인	파일 0600 시도; 운영 ACL 확인
3	배포 · 서버 설정 변경	systemd/환경변수	코드 · 체인 설정 · 소유자 키 변경	배포 직무 확인	미확인	ubuntu 실행 예시; 실권한 확인
4	DB 접근	DID/user/Token	DID 키 · 주소 · 지급 상태 조회/변경	DB 운영 직무 확인	미확인	DB 계정 · 승인 확인
5	외부 서명 환경	DChain 제공기관	체인 키 수신 · 거래 처리	제공기관 직무 확인	미확인	외부 접근 통제 확인
6						
7						
8						

□ 3. 다중서명 및 타임락 설정

항목	기재란
다중서명 임계값 (예: 5 인 중 3 인)	저장소에서 미확인; 외부 체인/솔루션 확인
임계값 설정 근거	적용 여부 및 설정 근거 확인 필요
서명자 키 보관 유형별 분포	서버 파일 · DB · 환경 설정 확인. 서명자별 분포 미확인
타임락 설정 시간	미확인
타임락 구간에 수행하는 검증 절차	미확인
서명자 변경 시 승인 절차	기업 확인 필요

7. 지갑 및 주소 인벤토리

주소는 실운영 목록 확인 후 기입합니다. 2번은 서버가 키를 보관하는 지갑군의 확인 후보이며 사용자 개인 지갑을 일괄 포함하지 않습니다. DID 서명키는 체인 주소가 아니므로 제외했습니다.

□ 작성 안내

- 서비스가 사용하는 지갑과 주소를 용도별로 기재한다.
- 잔액과 계층별 보관 비율은 기재하지 않는다. 제출된 주소를 기준으로 점검 수행사가 직접 산정한다.
- ※ 사용자 개인 지갑 주소는 대상이 아니다. 서비스가 관리하는 주소만 기재한다.

□ 1. 지갑 및 주소 목록

No.	식별명	체인	주소	용도	보관 유형	서명 방식	관리 주체
1	서버 소유자 지갑	DChain/minic 기본값	운영 주소 확인 필요	생성·지급·회수	온라인 서버 사용, 핫 추정	개인키 1개 전달; 체인 확인	운영 직무 확인
2	서버 키 보관 지갑군	DChain/minic 기본값	서비스 관리 대상만 별도 확인	레거시 지급·회수	로컬 JSON, 핫 추정	개인키 1개 전달; 체인 확인	키관리 직무 확인
3							
4							
5							
6							
7							
8							
9							
10							

□ 2. 지갑 솔루션 및 벤더

No.	솔루션명	공급사	적용 지갑	키 보관 방식	계약 범위
1	DChain 계정 API	제공기관 확인	소유자/연계 지갑	외부 API 생성 키; 서버 설정 또는 파일 사용	계약 · SLA 확인
2	SOH_DID 로컬 키 저장	자체 구현 (운영 법 인 확인)	서버 키 보관 지갑 군	wallet 객체의 키 를 JSON에 저장, 0600 시도	외부 위탁 여부 확 인
3					
4					

※ 키 보관 방식은 HSM, KMS, MPC, 시드 문구 물리 보관 등으로 기재한다.

SOH_DID 사전 요청 자료 기술설명서

작성일: 2026-09-18 | 소스코드 기반 검토본

검토 기준 커밋: 9f31eee2ca7a4261279074fd46859e0e74b2a73e

원본: 「사전 요청 자료 목록(기업 작성용).pdf」 3쪽, 1-51번 항목.

이 문서는 원본의 항목 번호에 대응하는 기업 입력란 답변 초안과 기술 별첨이다. 코드에서 확인된 동작을 작성했으며, 운영 환경·조직·정책의 실제 보유 여부는 확정하지 않았다. '저장소에서 미확인'은 기업의 '미보유'를 의미하지 않는다. 외부 서비스와 운영 DB에 접속하거나 실제 거래를 발생시키지 않았다. 비밀키·API 토큰·DB 비밀번호·실제 이용자 식별값은 수록하지 않았다.

1. 원본 항목별 답변

1-6. 기본 정보

- 조직도:** 기업 확인 필요. 부서 구성, CPO/정보보호 담당자의 직위·부서, 개인정보 취급 부서가 표시된 조직도를 별도 확보해야 한다.
- 임직원 수:** 기업 확인 필요. 정규직·비정규직 인원은 소스코드로 확인할 수 없다.
- 개발자/기술 인력 수:** 기업 확인 필요. 블록체인·백엔드·프론트엔드 담당 인원 구분이 필요하다.
- 보안 전담 인력 수:** 기업 확인 필요. 전담·겸직 여부와 인원을 확인해야 한다.
- 정보보호/개인정보보호 담당자:** 기업 확인 필요. 지정 여부와 직위를 확인해야 한다.
- 24x7 운영/관제:** 기업 확인 필요. 서비스 자동 재시작 설정은 있으나 상시 관제 인력·체계의 증거는 아니다.

7-14. 서비스·기술 구성

- 블록체인 서비스 개요:** 프로젝트명 SOH_DID. 로컬 DID 생성·조회·삭제, VC 발급·검증, VP 생성·검증, 대구체인 연계 지갑 생성, 토큰 생성·전송·회수·잔액 조회를 제공하는 Python Flask API이다. 영상별 토큰 지급 여부를 관리하는 DB 필드와 영상 시청 테스트 화면이 포함되어 있다. 공식 서비스명, 출시일, 실제 사용자 수는 기업 확인 필요. 근거: S1-S5, S7, S9.
- 블록체인 유형/플랫폼:** 대구체인(DChain)의 Mitum 경로 API를 연계한다. 기본 체인 설정값은 minic이며 기본 API 주소는 <https://www.daegu.go.kr/daeguchain/v2/mitum>이다. DID는 애플리케이션에서 did:key 형식으로 별도 생성한다. 퍼블릭/프라이빗/컨소시엄 구분 및 실제 연결망은 기업·체인 운영기관 확인 필요. 근거: S2, S6.
- 서비스 운영 단계:** 코드 및 EC2 배포 예시는 확인되지만, 메인넷 운영/테스트넷/출시 예정 여부는 기업 확인 필요. 근거: S8.
- 스마트컨트랙트 운영 여부/개수:** 외부 DChain API를 통한 토큰 생성, 컨트랙트 주소 저장, 전송·승인·발행·소각 요청 기능이 있다. 저장소에서 자체 컨트랙트 소스·컴파일러·빌드 설정은 확인되지 않았다. 실제 배포 수와 자체 개발 여부는 별도 확인 필요. 로컬 Token 테이블 건수만으로 실제 온체인 배포 수를 확정할 수 없다. 근거: S3, S6, S7.
- 지갑/수탁/키관리 기능:** 구현 있음. DID 키는 서버에서 Ed25519로 생성하고 체인 지갑은 외부 계정 생성 API로 발급한다. DID 키와 지갑 키를 서버 파일에 저장하며 DID 키는 MySQL에도 저장한다. 일부 체인 요청에 서버 소유자 키를 사용하고, 레거시 지갑 회수 시 저장된 지갑 키를 불러온다. 실제 수탁 서비스 해당 여부와 운영 보관 유형은 기업 확인 필요. 근거: S2, S3, S7. 상세: 별첨 C.
- 주요 시스템 구성:** 테스트 웹(HTML/JavaScript) → Flask API → 외부 DChain HTTPS API로 연계하며, Flask는 MySQL과 로컬 DID/키 파일 저장소를 사용한다. Gunicorn/systemd 배포 예시가 있다. 실제 서버·DB·노드 수 및 네트워크 구성은 기업 확인 필요. 근거: S1-S9. 상세: 별첨 A.
- 클라우드 사용/사업자:** AWS EC2용 배포 예시가 저장소에 있다. 실제 AWS 사용 여부, 계정·리전·리소스 수 및 관리 주체는 기업 확인 필요. 근거: S8.
- 노드 직접 운영:** 코드에서는 외부 DChain API 호출 방식을 확인했다. 직접 노드를 구동하는 설정은 저장소에서 미확인이다. 기업이 별도로 운영하는 노드의 유무·수·역할은 확인 필요. 근거: S4-S6.

15-22. 개인정보 및 관리체계

15. **개인정보 처리 여부:** 사용자 식별자, DID, 지갑주소 등 사용자 연계 데이터를 입력·저장하는 기능이 있다. 실제 개인정보 처리 여부와 범위는 실운영 데이터 및 다른 서비스와의 결합 관계를 확인해 확정해야 한다. 근거: S2, S7.
16. **처리 정보 유형:** DID, label/userIdentifier/id/user_id에서 받은 사용자 식별자, 계정 주소, 공개키·개인키, 생성시각, 영상별 토큰 지급 상태를 처리한다. VC 발급 요청의 claims는 임의 속성을 수용한다. DB에는 credential JWT·상태·유효기간 필드도 있으나 현재 로컬 VC 발급 라우트의 해당 DB 저장 호출은 확인되지 않는다. 이름·연락처·KYC·생체정보의 실수집 여부는 미확인이다. 개인키는 별도의 인증 비밀정보로 관리 대상이다. 근거: S2, S7.
17. **개인정보 처리방침:** 최신 방침 문서/URL은 저장소에서 미확인. 기업 보유 자료 확인 필요.
18. **만 14세 미만 대상 서비스:** 기업 확인 필요. 서비스 대상 연령과 법정대리인 동의 운영 내역은 코드로 확인할 수 없다.
19. **정보보호 정책/지침:** 승인된 정책·지침은 저장소에서 미확인. 기업 보유 문서명 확인 필요.
20. **최근 1년 취약점 점검:** 기관·일자·결과보고서는 미확인. 회수 API 테스트 코드는 있으나 취약점 점검 수행 증적에 해당한다고 단정할 수 없다. 근거: S10.
21. **ISMS/ISO27001 등 인증:** 기업 확인 필요. 인증명과 유효기간 증빙을 확인해야 한다.
22. **최근 3년 보안사고:** 기업 확인 필요. 코드만으로 사고 유무를 확인할 수 없다.

23-33. 블록체인 점검 자료

23. **블록체인 보안현황 조사서:** 제공된 서식1에 코드로 확인한 서비스·범위·외부 의존성을 기입했다. 기업명·담당자·운영 단계·조건부 항목은 기업 확인 필요.
24. **점검 대상 목록:** 서식2에 외부 DChain 계약·연계 노드·지갑·Flask/MySQL·로컬 키 저장소·테스트 웹을 후보로 기입했다. 실제 배포 주소, 자산 수량, 운영 URL은 확인 필요. 빈 예비행은 자산 부재를 뜻하지 않는다.
25. **아키텍처·설계 문서:** 저장소 구현을 토대로 별첨 A에 구성과 온체인·오프체인 데이터 구분을 작성했다. 이는 이번 검토에서 작성한 구현 설명이며 기존 승인 설계 문서로 간주하지 않는다. 체인 내부 저장 구조와 실제 네트워크 분리는 확인 필요.
26. **불변식/파라미터 명세:** 자체 컨트랙트 명세는 미확인. 백엔드에서 확인되는 입력 제한·기본값·성공 판정 조건을 별첨 D에 정리했다. 온체인 불변식 및 설정 근거를 대신하지 않는다.
27. **스마트컨트랙트 소스코드:** 본 저장소는 Flask 연계 백엔드이며 자체 컨트랙트 소스·컴파일러·컨트랙트 lockfile·fork 출처는 미확인이다. 백엔드 검토 기준 커밋은 문서 첫머리에 명시했다. 자체 컨트랙트를 별도로 보유하면 해당 저장소와 빌드·테스트 지침을 추가해야 한다. 근거: S1, S11.
28. **배포 스크립트/설정:** 백엔드용 main/deploy/ec2/soh-did.service와 soh-did.env.example이 있다. 컨트랙트 배포 스크립트·배포 계획서·롤백 절차는 미확인이다. 설정 파일 제출 시 비밀값을 제거한 사본을 사용해야 한다. 상세: 별첨 D.
29. **권한 구조 문서:** 서식6에 소유자 키·레거시 지갑 키·API/서명/배포/DB 접근 경로를 기입했다. 이는 코드 기반 권한 사용 현황이며 온체인 역할, 직무·인원·승인 정책은 기업 확인 필요.
30. **업그레이드 절차:** 프록시 업그레이드 가능 컨트랙트와 단계별 승인·검증 절차는 미확인이다. 적용 여부부터 별도 확인 필요.
31. **외부 의존성:** 서식5 22-26번과 별첨 A3에 DChain·MySQL·파일 저장소의 역할, 오류 영향, 대체 경로 미확인 사항을 회신했다. 실제 운영 주체·계약·SLA는 확인 필요.
32. **노드 설정 자료:** 노드 클라이언트·버전·P2P/RPC 공개 설정·노드/검증자 키 관리 설정은 저장소에서 미확인이다. 직접 운영 여부를 확인한 후 해당 시 별도 확보해야 한다.
33. **폐쇄형·자체 체인 자료:** genesis/chainspec, 참여 조직, 합의 구성, CA/MSP/채널 운영 자료는 저장소에서 미확인이다. 외부 체인의 실제 유형과 기업 운영 범위를 확인한 후 해당 여부를 정해야 한다.

34-45. 지갑·백엔드·운영 통제

34. **지갑 구성 자료:** 서식7에 소유자 지갑과 서버 키 보관 지갑군을 작성했다. 서비스 관리 대상 및 실제 주소를 확인해야 하며 일반 사용자 개인 지갑을 일괄 포함하지 않았다. DID 서명키는 체인 지갑 주소와 구분한다.
35. **키 관리 정책/절차:** 서버에서 Ed25519 키를 생성하고 로컬 JSON에 암호화 없이 저장하며 파일 권한 0600 설정을 시도한다. DID 개인키는 DB에도 저장한다. 체인 지갑 키는 외부 API에서 받아 같은 키 파일에 보관한다. 백업·복구·교체·입회·매체

완전삭제 절차는 미확인이다. /did/delete는 파일·인덱스를 삭제하지만 DB 키 삭제를 호출하지 않는다. 상세: 별첨 C.

36. **키 사용/서명 통제:** VC/VP 서명은 Flask 프로세스에서 수행한다. 체인 요청에는 개인키 필드를 DChain API로 전달한다. /token/retrieve는 요청의 송신자·수신자가 서버 소유자 주소와 일치하고 소유자 키가 일치해야 진행한다. 다른 라우트까지 이를 공통 적용하지는 않는다. MFA, 금액 한도, 목적지 허용목록, 다단계 승인, 별도 확인 채널은 저장소에서 미확인이다. 상세: 별첨 B-C.

37. **키 침해 대응:** 대응 정책·담당·연락망·긴급 자산 이전 절차·훈련 기록은 미확인이다. 배포 전 서비스라면 기업이 승인한 수립 계획이 필요하다.

38. **온체인 연계 백엔드:** API 목록, 전송·회수 흐름 및 실패 경로를 별첨 B에 작성했다. 입금 감지·확정 대기·중복 방지·재구성 롤백, 웹훅 검증 처리, 독립 체인 서명 서버는 이 저장소에서 미확인이다. 운영 시스템에 별도 구현이 있는지 확인해야 한다.

39. **관리자 콘솔:** 전용 관리자 콘솔, 로그인/MFA, 역할별 권한·계정 목록은 저장소에서 미확인이다. 테스트 웹을 운영 관리자 콘솔로 간주하지 않는다. 근거: S1, S9.

40. **프론트엔드/앱 및 서명 화면:** 테스트 웹은 http://127.0.0.1:5000의 DID 생성·목록·토큰 전송 API를 호출한다. 응답 JSON을 화면과 콘솔에 표시하며 별도의 서명 승인 화면은 미확인이다. 토큰명 예시 TOKEN_번호는 현재 서버 허용 목록과 불일치한다. 모바일 앱·개인키 저장 코드는 저장소에서 미확인이다. 실제 이용자 서비스 URL·RPC·주소 설정은 기업 확인 필요. 근거: S9, S7.

41. **온체인 모니터링:** 파일 로그와 일부 전송 실패 로그는 있으나 온체인 감시 주소·탐지 규칙·특권 함수 감시·알림 대응 체계는 저장소에서 미확인이다. 파일 로그 로테이션은 1MB, 백업 10개 설정이다. 근거: S1, S3.

42. **긴급 정지/사고 이력:** 코드에서 별도 출금 중지 스위치나 컨트랙트 pause 기능은 미확인이다. OS 서비스 중지는 가능하더라도 승인된 긴급정지 절차나 외부 체인의 정지를 의미하지 않는다. 실제 대응 절차·소요시간·사고 및 장애 이력은 기업 확인 필요.

43. **기존 감사/점검:** 감사 보고서·보안점검 결과·미조치 목록은 저장소에서 미확인이다. 테스트 코드와 본 문서는 감사 보고서를 대체하지 않는다.

44. **온체인 잔액/내부 원장 대사:** 잔액 조회 API와 로컬 사용자 토큰 상태 필드는 있으나 자동 대사·실행 기록·불일치 처리 절차는 미확인이다. increase_balance는 수량 누적이 아니라 지정 컬럼을 1로 설정한다. 회수 경로에는 해당 필드의 차감/초기화가 없다. 결제·정산 서비스 여부 및 별도 원장을 확인해야 한다. 근거: S3, S7.

45. **증적 표본:** 전체 요청·검토·승인·서명·전송·거래해시·원장 반영이 연결된 운영 표본은 이번 검토에서 검증하지 않았다. 테스트/샘플 파일을 실거래 증적으로 간주하지 않는다. 점검 수행사가 지정한 표본을 기업이 개인정보·비밀값을 가린 뒤 확보해야 한다.

46-51. 접근 환경 및 정보시스템

46. **점검 환경/접근권:** 저장소는 https://github.com/hanathomastone/SOH_DID이며 기준 커밋은 문서 첫머리에 명시했다. 읽기 전용 권한 부여, 테스트망/포크 환경 제공은 별도 협의 사항이다. 현재 코드에 민감한 기본 설정값이 있어 외부 제공 전 소스와 이력의 비밀정보 검토가 필요하다. 이번 작업에서는 접근권을 부여하지 않았다.

47. **자료반출 구분표:** 서식3의 24개 산출물에 기업 승인 전 조건부 제공안을 작성했다. 비밀키·토큰·비밀번호 원문은 제외하고 사본 마스킹·현장 열람 등 대체 방법을 제안했다. 반출 분류와 실제 제공은 기업 승인 후 확정해야 한다.

48. **시스템 상세정보:** 확인 가능 기술은 Python/Flask, Gunicorn, MySQL(PyMySQL 1.1.1 동봉), Linux/systemd 기반 EC2 배포 예시이다. Server Windows/Linux 수량, DBMS 버전·수량, Apache/Nginx 등 웹 서버, 방화벽/VPN/IDS/IPS/DDoS/WAF, 네트워크·가상화 장비, AWS 리소스의 실제 종류·버전·수량은 기업 확인 필요. 근거: S7-S8, S11.

49. **정보시스템 점검 스크립트 결과:** 점검용 스크립트와 가이드가 제공되지 않아 작성 불가. 운영 담당자가 대상 확정 후 실행 결과를 확보해야 한다.

50. **네트워크 장비 설정:** 장비 Config는 저장소에서 미확인. 운영 담당자 확인 및 비밀값 제거 사본이 필요하다.

51. **보안장비 사전 질의:** 별도 엑셀 질의 파일과 실제 장비 현황이 필요하다. 현재 소스만으로 작성할 수 없다.

별첨 A. 시스템·데이터·외부 의존성

A1. 코드에서 확인한 논리 구성

테스트 웹 → Flask API(/did, /token, /common) → DChain HTTPS API → 외부 체인 처리.

Flask API ↔ MySQL: DID/키/지갑주소, 사용자 식별자·상태, 토큰 메타데이터.

Flask API ↔ 로컬 파일: DID 문서, 개인키 파일, DID 인덱스. Flask API → 회전 로그 파일.

/mitum 접두 경로를 제거하는 미들웨어가 있어 /mitum/token/transfer 등의 요청도 같은 라우트로 연결된다. 별도 인증 경계가 아니다. 서버 수·망 분리·방화벽·리버스 프록시는 실제 구성 확인이 필요하다.

A2. 온체인/오프체인 데이터

- 온체인 처리 요청: 체인 계정 생성, 토큰 생성·전송·승인·발행·소각, 기본 통화 전송 등. 최종 온체인 기록 필드와 확정 규칙은 DChain 구현·응답 및 운영 증적으로 확인해야 한다.
- 오프체인 파일: dids/*.did.json, keys/*.key.json, index.json. DID 문서·생성시각·label·계정주소 및 DID/지갑 키를 저장한다.
- 오프체인 DB: DID 테이블의 DID/개인키/공개키/주소, user 테이블의 식별자·영상별 상태·credential 관련 필드, Token 테이블의 컨트랙트 주소·공급량·API 응답 메타데이터, keyValue 테이블.
- VC/VP: API 요청·응답에서 JWT를 처리한다. 현재 로컬 발급/생성 경로에 JWT 영구 저장 호출은 확인되지 않는다.
- DID 생성은 로컬 did:key 생성이며 DID 문서를 체인에 등록하는 호출은 이 경로에서 확인되지 않는다. 체인 지갑 생성과 구분한다.

A3. 외부 의존성 및 장애 영향

- DChain: 지갑 생성·토큰/체인 조회·변경 요청의 핵심 의존성. 응답이 잘못되면 주소·토큰 메타데이터 및 성공 판단에 영향을 준다. 기본 timeout 20초, timeout은 504, 연결/요청 오류는 502로 반환한다. 대체 API·자동 failover·거래 재시도 큐는 미확인이다. 실제 운영 사업자·지원체계는 별도 확인 필요.
- MySQL: DID/사용자/토큰 저장에 사용한다. 연결 재확인·재접속 처리가 있다. DID 저장 실패 시 DB 트랜잭션을 rollback하지만 이미 생성된 체인 지갑과 파일을 취소하지는 않는다. DB 복제·백업·대체 경로는 미확인이다.
- 로컬 디스크: 키가 없거나 잘못되면 DID/VC/VP 서명 및 레거시 회수에 영향을 준다. DID 인덱스는 임시 파일 교체와 프로세스 내부 lock을 사용한다. 여러 Gunicorn 프로세스 간 동기화·공유 파일 운영 방안은 확인 필요.
- Python 라이브러리: Flask, flask-cors, gunicorn, requests, cryptography, PyJWT. requirements는 버전을 고정하지 않는다. PyMySQL 1.1.1은 vendor에 동봉되어 있다. 실제 설치 버전은 실행환경에서 별도 확인해야 한다.

별첨 B. API 목록과 자산 이동 흐름

B1. 등록된 API 목록

다음 목록은 소스의 라우트 등록을 정적으로 추출한 범위이다. /mitum 접두 경로도 지원한다.

- DID 생성: POST /did/create, /did/create_account, /did/signup.
- DID 관리: GET /did/dids; POST /did/resolve, /did/delete.
- VC/VP: POST /did/issue-vc, /did/verify-vc, /did/present-vp, /did/verify-vp.
- 토큰 변경: POST /token/create, /token/transfer, /token/approve, /token/transfer_from, /token/retrieve, /token/mint, /token/burn, /token/upload_token.
- 토큰 조회: POST /token/balance, /token/balance_list, /token/supply, /token/allowance; GET/POST /token/tokens, /token/token_list; GET /token/local_tokens.
- 공통 설정: GET /common/endpoints, /common/dchain_config.
- 체인 조회: GET/POST /common/node_info, /common/chain_id, /common/rpc_node, /common/block_number.
- 계정/블록/거래 조회: POST /common/acc_balance, /common/acc_info, /common/block_by_hash, /common/block_by_num, /common/trx_info, /common/trx_count.
- 계정/자산 변경: POST /common/acc_create, /common/acc_faucet, /common/cur_transfer.

B2. 토큰 전송 흐름과 실패 분기

요청 → token_name 정규화·허용 목록 검사(지정한 경우) → user_DID로 수신 주소 조회(지정한 경우) → 토큰 컨트랙트 조회(이름만 지정한 경우) → 송신자·키 기본값 보완 → DChain 요청 → HTTP 200 및 state=OK 확인 → DID와 token_name이 있으면 사용자 상태 컬럼을 1로 설정 → DB commit → 응답.

- 거부 조건: 허용되지 않은 token_name은 400, 찾을 수 없는 user_DID는 404, 이름으로 찾을 수 없는 컨트랙트는 400이다.
- 외부 전송 실패: 실패 로그를 남기고 외부 응답 또는 프록시 오류를 반환한다. 이 경우 로컬 상태 갱신은 하지 않는다.
- 외부 전송 성공 후 DB 실패: 외부 거래와 로컬 DB를 묶는 원자적 트랜잭션·보상 처리·재처리 기록은 미확인이다. DB 오류가 발생해도 외부 거래가 취소되는 것은 아니다.
- 상태 갱신은 전송 수량과 무관하게 1을 기록한다. 지급 완료 상태와 실제 잔액을 구분해야 한다.

B3. 회수 흐름과 실패 분기

POST /token/retrieve → 송신자/수신자 주소가 서버 소유자와 일치하는지 검사 + sender_pkey 비교 → 불일치 시 403 → holder의 로컬 지갑 키 탐색 → 키가 있으면 해당 계약·요청 수량에 대해 소유자 allowance 승인 → 승인 성공 시 transfer_from 호출 → 응답.

승인 실패 시 stage=approve 오류로 종료하며 transfer_from은 호출하지 않는다. 로컬 키를 찾지 못하면 추가 approve 없이 기존 transfer_from 프록시로 진행한다. 승인 성공 후 전송 실패 시 allowance 취소·보상 흐름은 확인되지 않는다. /token/transfer_from을 직접 호출하는 경로에는 /retrieve의 소유자 비교 분기가 적용되지 않는다. 실제 외부 검증 정책은 별도 확인 대상이다.

B4. 자산 이동 및 거래 유발 후보 경로

- 직접 이동 요청: /token/transfer, /token/transfer_from, /token/retrieve, /common/cur_transfer.
- 공급량·승인 변경: /token/create, /token/mint, /token/burn, /token/approve. retrieve 내부에서도 approve가 호출될 수 있다.
- 기타 체인 변경 후보: /common/acc_create, /common/acc_faucet, DID 생성 3개 별칭의 지갑 생성 호출, /token/upload_token. 실제 거래 생성 여부와 영향은 외부 API 구현에 따라 확인 필요.
- 입금 처리: 잔액·거래 조회 프록시는 있지만 입금 watcher, 확정 블록 수 기준, 중복 처리 키, 재구성 롤백 및 웹훅/콜백 검증 라우트는 미확인이다.

별첨 C. 키·지갑·권한 현황

C1. 용도별 키 인벤토리 초안

- DID 서명 키: Flask 프로세스에서 Ed25519PrivateKey.generate()로 생성. cryptography 라이브러리에 난수 생성을 위임하며 별도 엔트로피 장비·입회 기록은 미확인. DID 문서·VC·VP 기능에 사용한다. 개인키는 hex 문자열로 JSON과 DID 테이블에 저장한다.
- 사용자 체인 지갑 키: DChain /com/acc_create 응답에서 수신. DID 키 파일의 wallet 객체에 주소·공개키·개인키를 함께 저장한다. 레거시 회수의 allowance 승인에 사용한다. 외부 키 생성 환경과 알고리즘은 코드만으로 확인할 수 없다.
- 서버 소유자 체인 키: DCHAIN_OWNER_PRIVATE와 DCHAIN_OWNER_ADDR 설정을 사용한다. 토큰 생성·발행·전송의 기본 값과 회수 인증에 관여한다. 기본 비밀값이 코드에 포함되어 있어 제출본에는 값을 신지 않았다.

C2. 저장·노출·삭제 동작

저장 경로는 DID_DATA_DIR → DATA_DIR → ./data 순으로 결정된다. 키 파일은 JSON 직렬화로 저장하고 파일 권한 0600을 시도하지만 실패를 무시한다. 실제 OS ACL, 디스크/DB 암호화, 백업 접근권은 별도 확인이 필요하다. HSM/KMS/MPC 연계는 이 저장소에서 확인되지 않는다.

DID 생성 성공 응답에는 DID 개인키와 체인 wallet 객체가 포함된다. 테스트 웹은 응답 전체를 화면과 콘솔에 출력하므로 키도 출력될 수 있다. 회수 API에서 키를 직접 반환하지 않는다는 사실을 전체 API의 키 비노출 정책으로 확대해서는 안 된다.

/did/delete는 DID 문서·키 파일·인덱스를 삭제한다. DB의 DID/user 행, 복제본·백업, 클라이언트에 전달한 키의 폐기를 처리하지 않는다. 파일 unlink는 매체 완전삭제의 증거가 아니다.

C3. 구현된 통제와 확인할 통제

- 공통 DChain 연계: 클라이언트가 넘긴 token/chain 대신 서버 설정을 사용한다. 이는 외부 서비스 호출 인증이며 앱 호출자의 로그인·업무 권한 확인을 의미하지 않는다.
- retrieve 전용 통제: 송신자·수신자 주소 비교 및 hmac.compare_digest를 이용한 소유자 키 비교. 다중서명/MFA/분리 승인에 해당하지 않는다.
- 기타 기능: Flask 등록 코드와 라우트에서 공통 사용자 인증·역할 기반 권한 검사는 미확인이다. API Gateway·네트워크·상위 서비스의 별도 통제는 기업 확인 필요.
- 체인 서명: 본 앱은 private key 필드를 외부 DChain으로 전송한다. 외부 서명 서버의 실제 구성·격리·권한은 미확인이다. 로컬 VC/VP 서명은 API 프로세스에서 실행한다.
- 로깅: 토큰 전송 실패 로그에 특정 private key 키명을 마스킹한다. 모든 로그·오류 응답·중첩 문자열의 비밀정보 제거가 보장된다고 볼 수 없다.
- 운영 절차: 키 생성 입회·백업·분산 보관·복구 시험·정기 교체·긴급 이전·폐기·승인 채널·담당 직무는 모두 기업 확인 필요.

별첨 D. 파라미터·배포·검증 범위

D1. 코드에서 확인한 조건과 기본값

- 체인 설정: 기본 DCHAIN_CHAIN_NAME=minic, 요청 timeout 20초. 운영 환경변수로 달라질 수 있다.
- 토큰 생성: decimals 미지정 시 9. token_name 정규화 실패를 즉시 거부하지 않고 외부 요청으로 진행하는 분기가 있다.
- 토큰 전송: token_name을 지정하면 ESSENTIAL_VIDEO_1-5 또는 OPTIONAL_VIDEO_1-7로 정규화·제한한다. user_DID가 있으면 amount 미지정 시 1을 사용한다. amount 양수·상한 등의 공통 검증은 이 라우트에서 미확인이다.
- 소유자 기본값: 생성·mint의 owner 및 전송의 sender/key는 setdefault 방식이다. 요청이 값을 지정하면 서버 기본값으로 강제 교체하지 않는다. token/chain의 강제 서버 설정과 구분해야 한다.
- VC/VP: VC 기본 TTL 3600초, VP 기본 TTL 300초. TTL을 정수 변환하며 명시적 허용 상한·양수 제한은 미확인이다. 검증은 EdDSA 및 필수 시간/발급자 클레임을 검사한다. VC audience 검사는 aud가 제공될 때, VP 검증은 aud 필수 조건으로 적용된다.
- 성공 조건: 토큰 생성 저장·전송 후 상태 갱신은 HTTP 200 및 body.state=OK를 사용한다. 독립적인 온체인 확정 확인 기준은 미확인이다.

D2. 배포 예시에서 확인된 값

Linux/systemd에서 ubuntu 사용자-www-data 그룹으로 Gunicorn을 실행한다. 작업 경로 예시는 /opt/soh-did/current, 환경 파일은 /etc/soh-did/soh-did.env, 바인딩은 127.0.0.1:5000이다. Gunicorn은 workers 2, threads 4, timeout 60초이며 자동 재시작 설정이 있다. 실제 적용 여부는 미검증이다.

필요 설정 범주는 DCHAIN_BASE_URL/API_TOKEN/CHAIN_NAME/TIMEOUT/OWNER_ADDR/OWNER_PRIVATE, MYSQL_HOST/PORT/USER/PASSWORD/DATABASE, DID_DATA_DIR 또는 DATA_DIR, APP_LOG_DIR이다. 값은 운영 담당자가 안전한 경로로 제공해야 한다.

직접 run.py를 실행하면 0.0.0.0:5000, debug=True로 실행한다. 이것을 운영 배포 설정으로 간주하지 않는다. Python·MySQL·설치 패키지의 실제 버전, 리버스 프록시·TLS·접근 제어와 비밀값 제거 배포본은 별도 확인 필요.

D3. 이번 작성의 검증 범위

원본 PDF 3쪽과 항목 번호 1-51을 확인하고 라우트·저장 로직·배포 예시를 정적으로 검토했다. 운영 DB/체인 호출, 실제 거래, 운영 서버 점검과 보안 취약점 재현은 수행하지 않았다. 기존 main/tests/test_token_retrieve.py는 확인했지만 실행하지 않았다. 모듈 import 과정에서 DB 초기화가 발생할 수 있으므로 완전한 외부 의존성 격리를 먼저 마련해야 한다.

근거 파일 색인

다음 경로는 검토 기준 커밋의 저장소 루트 기준이다. 비밀값이 포함될 수 있는 파일은 원문을 그대로 외부 제출하지 않는다.

- S1: main/run.py, main/myapp/__init__.py - 앱 등록·미들웨어·로그·CORS·실행 설정.

- S2: main/myapp/routes/did.py - DID 생성·파일/DB 저장·VC/VP·삭제.
- S3: main/myapp/routes/token.py - 토큰 생성·전송·승인·회수·외부 프록시.
- S4: main/myapp/routes/common.py - 체인·계정·블록·거래 API.
- S5: main/myapp/dchain.py - 서버 인증 설정·HTTP 요청·오류 처리.
- S6: main/myapp/utlis.py - 외부 주소·체인·엔드포인트·환경변수. 민감한 기본값 포함.
- S7: main/myapp/mysql_db.py, DID_db.py, USER_db.py, Token_db.py 및 각 조회 모듈 - 스키마·데이터 저장/조회.
- S8: main/deploy/ec2/soh-did.service, soh-did.env.example - 배포 예시.
- S9: test_web.html, test_script.js - 테스트 화면·API 호출.
- S10: main/tests/test_token_retrieve.py - 회수 동작 테스트 코드.
- S11: main/requirements.txt, main/vendor/PyMySQL-1.1.1.dist-info/METADATA - 의존성 목록.

기업에서 보완할 정보

조직/담당/인원, 실제 서비스명·출시일·사용자 수·운영 단계, 연결 체인 유형, 운영 URL·서버/DB/노드/장비 수와 버전, 실제 지갑·컨트랙트 주소 목록, 개인정보 처리방침 및 대상 연령, 보안 정책·인증·점검·사고 이력, 키관리/권한/승인/모니터링/긴급정지/대사 절차와 운영 증거를 확인해야 한다. 서식1-7의 작성본을 함께 제공한다. 서식4의 확인 필요는 보유·해당 여부를 확정하기 전 임시 상태이며, 미보유나 해당 없음으로 임의 판정하지 않았다. 49-51번의 후속 점검 자료와 회사 운영 증거는 별도로 확보해야 한다.

작성 묶음 확인 사항

제공된 PDF 원본의 기업 입력란 51개와 HWP 서식1-7을 작성했다. 서식5의 58개 질의, 서식3·4의 산출물 24개를 모두 다뤘다. 서식4의 제출 표기는 작성 묶음 포함 기준이며 이메일 발송·접근권 부여·대외 제출 완료를 의미하지 않는다. 원본 문서 안의 제출 안내는 자료 요구사항으로만 취급했으며, 외부 전송은 하지 않았다.